



PS-NC-006

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v02 – Octubre del 2019

	Responsable	Fecha	Firma
Elaborado	Rodrigo Vidal / Encargado PMG SSI	Octubre 2019	
Revisado	José Villa / Área Seguridad de la Información (Representante Comité de Seguridad)	Octubre 2019	
Aprobado	Gabriel Reveco / Encargado Ciberseguridad (Presidente Comité de Seguridad de la Información)	Octubre 2019	



POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 2 de 10

Contenido

1	PROPOSITO	3
2	ALCANCE O AMBITO DE APLICACIÓN	3
3	MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS	4
4	ROLES Y RESPONSABILIDADES	4
5	MATERIAS QUE ABORDA.....	4
6	DIRECTRICES DE LA POLÍTICA.....	4
6.1	Seguridad de la información en la administración de proyectos	5
6.2	Seguridad de la información en los Proceso de compras.....	5
	Convenio Marco.....	6
	Compras a través de Licitación o Propuesta Pública	6
	Compras a través de Trato o Contratación Directa.....	7
6.3	Monitoreo y revisión de los servicios del proveedor	7
6.4	Administración de cambios en los servicios del proveedor	8
7	MECANISMO DE DIFUSIÓN.	9
8	PERÍODO DE REVISIÓN.	9
9	EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA	9
10	HISTORIAL Y CONTROL DE VERSIONES	10

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 3 de 10

1 PROPOSITO

Definir las reglas de seguridad para el resguardo de la información personal sensible para la gestión de los proyectos y monitoreo de los acuerdos de servicio, en los procesos relacionados de compra y administración de los servicios al interior de Minsal.

2 ALCANCE O AMBITO DE APLICACIÓN

Esta política es aplicable a los proyectos o servicios donde se encuentre involucrado el uso o tratamiento de datos sensibles, según lo declara la Ley 19.628.

Datos sensibles, aquellos datos personales que se refieren a las características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, tales como los hábitos personales, el origen racial, las ideologías y opiniones políticas, las creencias o convicciones religiosas, los estados de salud físicos o psíquicos y la vida sexual.

Se incluyen los datos que se refieran a los estados de salud presente, pasado, futuro o pronosticado de una persona, incluyendo cualquier información o comportamiento que permita identificar alguna situación médica.

Es aplicable a todos los funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para la Subsecretaría de Salud Pública y la Subsecretaría de Redes Asistenciales.

En cuanto a las temáticas de protección abordadas, el ámbito de aplicación de esta política corresponde al (a los) Dominio(s) de Seguridad de la Información y Controles de Seguridad respectivos, detallados a continuación:

Alcance de Dominios y Controles de Seguridad de la Información (Nch-ISO 27001:2013)		
Nombre del Dominio	ID Control ISO 27001	Nombre del Control
Organización de la seguridad de la información	A.06.01.05	Seguridad de la información en la gestión de proyecto
Relaciones con el proveedor	A.15.02.01	Supervisión y revisión de los servicios del proveedor
	A.15.02.02	Gestión de cambios a los servicios del proveedor

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 4 de 10

3 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS

- Marco Normativo
 - NCh-ISO27001:2009: Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de la seguridad de la información – Requisitos.
 - El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
 - Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
 - Leyes relacionadas
 - Ley N°19.628, de 1999, Ministerio Secretaría General de la Presidencia, sobre protección de la vida privada.
 - Ley N° 20.285, de 2008, Ministerio Secretaría General de la Presidencia, sobre acceso a la información pública.
 - Ley N° 20.584, de 2012, Ministerio de Salud, Subsecretaría de Salud Pública, regula derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud, y sus reglamentos asociados.
 - Resolución Exenta N° 636 del 12.08.2011 “Aprueba Manual de Procedimientos de Adquisiciones del Ministerio de Salud”.
 - Resolución Exenta N°1305 del 08.11.2016 “Modifica Manual de Procedimientos de Adquisiciones del Ministerio de Salud, Resolución exenta N°636”.
- Documentos Relacionados
 - Política para acuerdos de intercambio de información y software.
 - Procedimiento acuerdos de confidencialidad en contratos con terceros.
 - Política de Seguridad para las Relaciones con los Proveedores.

4 ROLES Y RESPONSABILIDADES

- **Jefe de División o Departamento.**
 - Definir a un funcionario o equipo, responsable de la administración de proyectos y los acuerdos de servicios.
- **Funcionario o equipo responsable**
 - Dar cumplimiento a los requisitos definidos en esta política en la administración de proyectos y los acuerdos de servicio.

5 MATERIAS QUE ABORDA.

- Seguridad de la información en la gestión de proyecto
- Supervisión y revisión de los servicios del proveedor
- Gestión de cambios a los servicios del proveedor

6 DIRECTRICES DE LA POLÍTICA

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 5 de 10

6.1 Seguridad de la información en la administración de proyectos

En todo proyecto donde esté relacionado el uso o tratamiento de datos de carácter sensible, se debe abordar la seguridad de la información en el diseño, y administración del proyecto, sin importar el tipo de proyecto (proceso comercial, TI, administración de instalaciones, procesos de apoyo, etc.). Se debe identificar y abordar los riesgos de seguridad de la información como parte del proyecto.

Dentro de la administración del proyecto se debe incluir:

- Dentro de los objetivos del proyecto se deben incluir objetivos de seguridad de la información en concordancia con la información personal sensible tratada.
- Una evaluación de los riesgos¹ de para la protección de los datos sensibles² para identificar los controles necesarios.
- Una evaluación de los riesgos de seguridad de la información en una etapa temprana del proyecto para identificar los controles necesarios;
- La seguridad de la información debe ser parte de todas las etapas del proyecto, independiente de la metodología utilizada.

En este tipo de proyectos, la Jefatura responsable debe definir un funcionario que actuará como responsable para la seguridad de la información (puede ser el Jefe de proyecto o parte del equipo del proyecto), quien será el responsable que el proyecto incluya los objetivos y requerimientos de seguridad de la información.

En los proyectos que requieran compras se deben seguir las pautas de seguridad de la información definidas en el punto 6.2 de la presente política.

6.2 Seguridad de la información en los Proceso de compras

Los procesos de compra se llevarán a cabo de acuerdo a lo definido en la Resolución Exenta N° 636 del 12.08.2011 “Aprueba Manual de Procedimientos de Adquisiciones del Ministerio de Salud” y sus modificaciones, a saber, compras a través de:

¹ Se trata de un ejercicio de análisis de los riesgos que un determinado sistema de información, producto o servicio puede entrañar para el derecho fundamental a la protección de datos de los afectados y, tras ese análisis, afrontar la gestión eficaz de los riesgos identificados mediante la adopción de las medidas necesarias para eliminarlos o mitigarlos.

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 6 de 10

Convenio Marco
Licitación o Propuesta Pública
Licitación o Propuesta Privada
Trato o Contratación Directa.

Además de incluir las cláusulas de confidencialidad establecidas en el “Procedimiento de acuerdos de confidencialidad en contratos con terceros”. Se deberán para aquellos procesos de compras asociados a proyectos donde se encuentre involucrado el manejo o tratamiento de datos personales, incluir cláusulas que permitan proteger la información, dependiendo del tipo de compra:

Convenio Marco

Compras Menores a 1.000 UTM:

Antes de la compra debe existir una revisión del bien o servicio para asegurar que cumple con los requisitos de seguridad de la información definidos en las etapas tempranas del proyecto.

Grandes compras Mayores a 1.000 UTM

Además de la revisión de los bienes y servicios, se deben definir los requisitos de seguridad de la información para resguardar la integridad, confidencialidad y disponibilidad de la información asociada al proyecto y deben ser establecidos en:

Especificaciones técnicas y administrativas.
Acuerdo complementario.

Compras a través de Licitación o Propuesta Pública

Antes de la compra debe existir una revisión del bien o servicio para asegurar que cumple con los requisitos de seguridad de la información definidos en las etapas tempranas del proyecto.

Además, se deben definir los requisitos de seguridad de la información para resguardar la integridad, confidencialidad y disponibilidad de la información en:

Licitación o Propuesta Pública Menor a 100 UTM

- Términos de referencia.

Licitación o Propuesta Pública entre 100 y 1.000 UTM

- Bases de Licitación.
- Contrato.

Licitación o Propuesta Pública entre 1.001 UTM y 4.999 UTM

- Bases de Licitación.

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 7 de 10

- Contrato.

Licitación o Propuesta Pública mayor o igual a 5.000 UTM

- Bases de Licitación.
- Contrato.

Compras a través de Trato o Contratación Directa

Antes de la compra debe existir una revisión del bien o servicio para asegurar que cumple con los requisitos de seguridad de la información definidos en las etapas tempranas del proyecto.

Además, se deben definir los requisitos de seguridad para resguardar la integridad, confidencialidad y disponibilidad de la información en:

Compras Menores a 1.000 UTM a través de Trato Directo

- Resolución que aprueba el trato directo.

Compras Mayores a 1.000 UTM a través de Trato Directo

- Resolución que aprueba el trato directo.
- Contrato.

6.3 Monitoreo y revisión de los servicios del proveedor

En los servicios de proveedores donde se vea involucrado el uso o tratamiento de datos sensibles la División o Departamento encargada de la administración del acuerdo, debe mantener el control y la visibilidad suficientes en todos los aspectos de seguridad para la información o las instalaciones de procesamiento de información personal sensible y crítica que evalúa, procesa o administra un proveedor.

Para lo anterior, el Jefe de la División o Departamento debe definir un funcionario o equipo responsable de administrar las relaciones con el proveedor³, quienes deberán monitorear, revisar y auditar la prestación de servicios del proveedor de manera regular.

Este monitoreo y revisión de los servicios debe garantizar que se incluyan términos y condiciones de seguridad de la información en los acuerdos definidos en los procesos de compra, y que estos se respeten y que los incidentes y los problemas de seguridad de la información se gestionen correctamente, esto incluye:

³ El administrador del acuerdo no debe ser necesariamente la contraparte técnica para el acuerdo.

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 8 de 10

- a) Monitorear los niveles de desempeño del servicio con el fin de verificar la adherencia a los acuerdos;
- b) Revisar los informes de servicio producidos por el proveedor y organizar reuniones de avance de manera regular según lo requieren los acuerdos;
- c) Realizar auditorías de los proveedores, en conjunto con la revisión de informes de auditores independientes, en caso de estar disponibles y, un seguimiento de los problemas identificados (para llevar a cabo esta acción se deberían incluir en los contratos que Minsal se reserva el derecho de auditar los servicios prestados, software o producto);
- d) Proporcionar información sobre los incidentes de seguridad y revisar esta información según sea necesario conforme a los acuerdos y a cualquier pauta o procedimiento de apoyo;
- e) Revisar los seguimientos de auditoría del proveedor y los registros de eventos de seguridad de la información, los problemas operacionales, seguimiento de todas las fallas e interrupciones relacionadas con el servicio entregado;
- f) Resolver, gestionar y/o escalar cualquier problema, incidente o evento de seguridad de la información, identificados en los puntos anteriores; así como monitorear la realización de las acciones inmediatas y acciones correctivas / preventivas que permita la resolución de los mismos;
- g) Asegurar que el proveedor cumple con las prohibiciones del uso secundario de la información sensible definidos en la compra del servicio, los procedimientos y controles específicos, la criticidad de la información, los sistemas y procesos involucrados.
- h) Asegurarse de que el proveedor mantiene una capacidad de servicio suficiente junto con planes de trabajo diseñados para garantizar que se mantienen los niveles de continuidad en el servicio luego de grandes fallas o desastres en el servicio.

6.4 Administración de cambios en los servicios del proveedor

Cuando existan cambios en la provisión de los servicios, estos deben ser administrados por el funcionario o equipo asignado para el monitoreo, y revisión de los servicios del proveedor. Esta administración de los cambios se debe realizar considerando la mantención y/o mejora de los requisitos de seguridad de la información definidos en la compra del servicio, los procedimientos y controles específicos, la criticidad de la información, los sistemas y procesos involucrados, junto con la reevaluación de los riesgos. Además de lo mencionado se deben considerar los siguientes aspectos:

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 9 de 10

- a) Cambios a los acuerdos del proveedor;
- b) Los cambios realizados por la organización por implementar:
 - mejoras a los servicios que se ofrecen actualmente;
 - desarrollo de cualquier nueva aplicación y sistemas
 - las modificaciones o actualizaciones de las políticas y procedimientos de la organización;
 - controles nuevos o cambiados para resolver incidentes de seguridad de la información y mejorar la seguridad;
- c) Cambios en los servicios del proveedor a implementarse;
 - cambios y mejoras en las redes;
 - uso de nuevas tecnologías;
 - adopción de nuevos productos o nuevas versiones;
 - nuevas herramientas y entornos de desarrollo;
 - cambios en la ubicación física de las instalaciones de servicios;
 - cambio de proveedores;
 - cambios en el equipo del proveedor;
 - subcontratación a otro proveedor.

7 MECANISMO DE DIFUSIÓN.

La comunicación de la presente política se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

8 PERÍODO DE REVISIÓN.

La revisión del contenido de esta Política se efectuará a lo menos cada dos años por el Comité de Seguridad de la Información, o atendiendo necesidades de cambios para garantizar su idoneidad, adecuación y efectividad.

9 EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA

Frente a casos de especiales, el Comité de Seguridad de la Información evaluará y podrá establecer condiciones puntuales de excepción en el cumplimiento de las presentes directrices, siempre que no infrinja la legislación vigente. Toda excepción debe ser documentada y generar un proceso de revisión de la política, que determine si se deben agregar directrices en lo particular.

POLITICA DE SEGURIDAD EN LA GESTION DE PROYECTOS Y MONITOREO DE LOS ACUERDOS DE SERVICIO				
	Sistema de Gestión de Seguridad de la Información – Nivel Central			
	MINISTERIO DE SALUD	ID: PS-NC-006	Versión: 02.00	Página 10 de 10

10 HISTORIAL Y CONTROL DE VERSIONES

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
01	Noviembre 2016	Creación del documento	Todo el documento
02	Octubre 2019	Todas	Se ajusta el formato del documento. Se modifica las referencias normativas. Se modifica el alcance del documento.